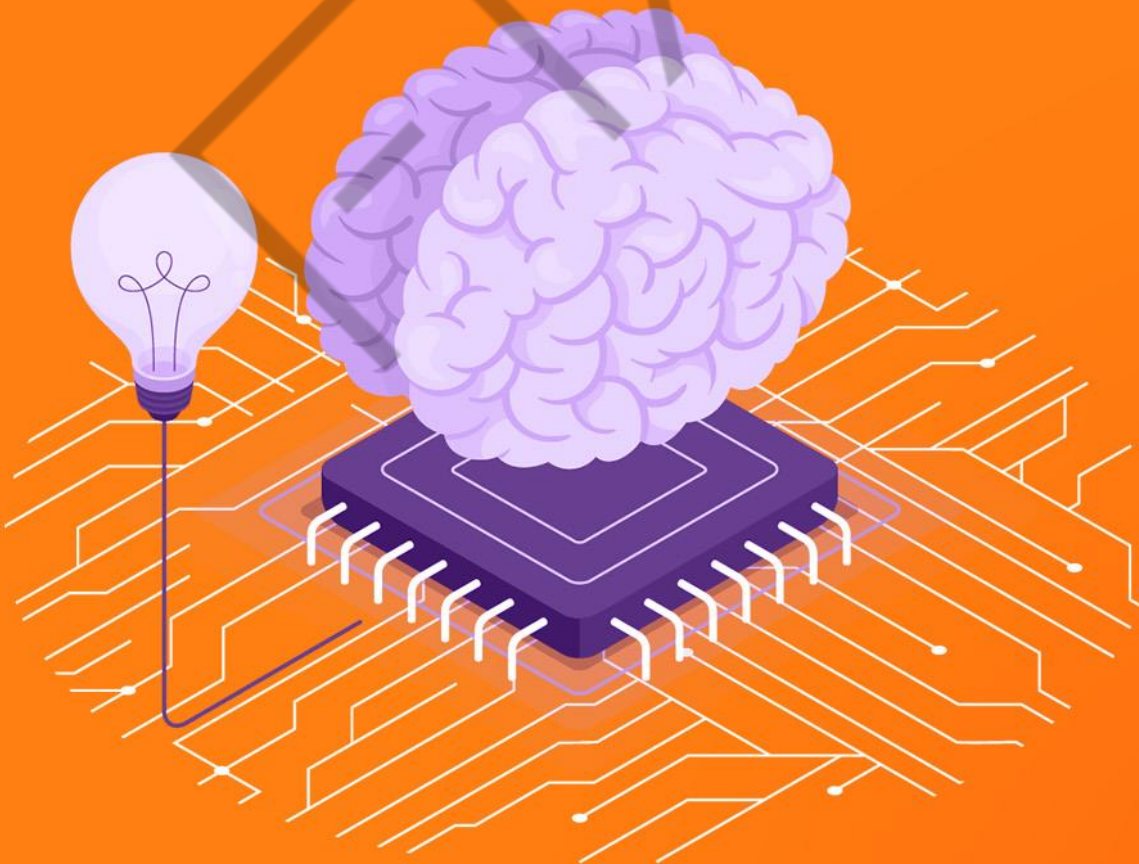


OFFSEC

OFFENSIVE MINDSET



11

LISTA DE FIGURAS

Figura 1 - Pilares da segurança da informação	7
Figura 2 - Interface Web OpenVas I	9
Figura 3 - Interface Web OpenVas II	10
Figura 4 - Interface Nessus profissional	11
Figura 5 - Modalidades de Pentest.....	13
Figura 6 - Configuração e instalação Kali Linux I	21
Figura 7 - Configuração e instalação Kali Linux II	21
Figura 8 - Configuração e instalação Kali Linux III	22
Figura 9 - Configuração instalação Kali Linux IV	22
Figura 10 - Configuração e instalação Kali Linux V	23
Figura 11 - Configuração e instalação Kali Linux VI	23
Figura 12 - Configuração e instalação Kali Linux VII	24
Figura 13 - Configuração e instalação Kali Linux VIII	24
Figura 14 - Configuração e instalação Kali Linux IX	25
Figura 15 - Configuração e instalação Kali Linux X	25
Figura 16 - Configuração e instalação Kali Linux XI	26
Figura 17 - Configuração e instalação Kali Linux XII	26
Figura 18 - Configuração e instalação Kali Linux XIII	27
Figura 19 - Configuração e Instalação Kali Linux XIV	27
Figura 20 - Configuração e instalação Kali Linux XV	28
Figura 21 - Configuração e instalação Kali Linux XVI	29
Figura 22 - Configuração e instalação Kali Linux XVII	29
Figura 23 - Configuração e instalação Kali Linux XVIII	30
Figura 24 - Configuração e instalação Kali Linux XIX	31
Figura 25 - Configuração e instalação Kali Linux XX	31
Figura 26 - Configuração e instalação Kali Linux XXI	32
Figura 27 - Configuração e instalação Kali Linux XXII	32
Figura 28 - Configuração e instalação Kali Linux XXIII	33
Figura 29 - Configuração e instalação Kali Linux XXIV	33

LISTA DE QUADROS

Quadro 1 - Especificações do Kali Linux.....	20
--	----

EMANIP

SUMÁRIO

1 OFFENSIVE MINDSET	5
1.1 Introdução ao conceito de Pentest	5
1.1.1 Pilares da segurança.....	6
1.2 Tipos de teste de segurança	7
1.2.1 Análise de vulnerabilidades	8
1.2.2 Red team.....	11
1.2.3 Pentest	12
2 MODALIDADES DE PENTEST	12
2.1 Black box.....	13
2.2 White box	14
2.3 Grey box.....	15
3 ETAPAS DO PENTEST	15
3.1 Preparação	16
3.2 Coleta de informações.....	16
3.3 Mapeamento ou varredura de rede	17
3.4 Enumeração de serviços	17
3.5 Análise de vulnerabilidades.....	18
3.6 Exploração de vulnerabilidades.....	18
3.7 Pós-exploração	19
3.8 Relatório	19
4 INSTALAÇÃO DO KALI LINUX	20
REFERÊNCIAS.....	34

1 OFFENSIVE MINDSET

1.1 Introdução ao conceito de Pentest

Definir o conceito de Pentest ou testes de invasão consiste em introduzir-se a uma área de muito conhecimento. Na era digital, fazer parte de um mundo tecnológico e integrado se tornou uma necessidade. As abordagens de consumo, preferências, costumes, família, lazer e trabalho ganharam um tom compartilhado e vulnerável. Nas redes sociais, observamos que a exibição é comum, classificada como influência digital. Ao mesmo tempo que essa influência digital proporciona comodidade, praticidade e ganhos consideráveis, ela insere uma falha de segurança gravíssima em nossa rotina. Com isso, sem conhecimento, fornecemos informações valiosas para grupos criminosos digitais ou não. Informações associadas ao local de trabalho, por exemplo, podem fornecer não só o acesso, mas, no mínimo, um meio de se conseguir o objetivo final de roubo de dados, por exemplo.

A cada novo dia, incorporamos de forma inconsciente, nossa vida à rotina do trabalho ou a ele propriamente dito. Essas incorporações podem ser observadas através de senhas em sistemas informáticos, acessos físicos e outros. Embora essas opções possuam segurança implementada, ainda existe 1% de possibilidade de falha na segurança, associada ao ser humano, operador da tecnologia em questão. Nesse contexto, os testes de invasão são ferramentas fundamentais, na descoberta, na observação, na manipulação e, principalmente, na correção de falhas. Por meio deles, busca-se prever o problema a fim de solucionar as falhas de segurança que nunca se apresentam no momento de seu desenvolvimento, mas, sim, na usabilidade diária.

Uma falha de segurança pode trazer prejuízos incalculáveis que afetam não só a estrutura financeira e física de uma corporação, mas a vida de terceiros os quais, eventualmente, foram apenas influenciados pelo mundo digital.

Segundo Weidman (2014):

Testes de invasão ou pentesting envolvem a simulação de ataques reais para avaliar os riscos associados a [sic] potenciais brechas de segurança. Em um teste de invasão (em oposição a uma avaliação de vulnerabilidades), os pentesters não só identificam vulnerabilidades que poderiam ser usadas pelos invasores, mas também exploram essas vulnerabilidades, sempre que possível, para avaliar o que os invasores poderiam obter após uma exploração bem-sucedida das falhas (WEIDMAN, 2014, p. 576).

Diante do que foi apresentado anteriormente, o Pentester é o profissional que executa testes de invasão. Essa profissão surgiu como uma necessidade na evolução tecnológica, e está cada vez mais consolidada no mercado, pois realizar testes de invasão tornou-se essencial à rotina digital. No entanto, mesmo com os avanços tecnológicos, a profissão do Pentester e os seus testes de invasão encontram certa resistência e desconfiança. Evidentemente, a mente humana não evolui como a máquina, mas para o uso dela.

Vale ressaltar que, por muito tempo, presenciamos notícias e relatos de ataques cibernéticos a ambientes corporativos, governamentais e financeiros. Todos esses ataques, dentro de uma visão preventiva, poderiam ter sido facilmente evitados, se um teste de invasão tivesse sido executado. Os testes de vulnerabilidade possuem como foco principal identificar falhas prévias existentes em redes e em sistemas informatizados, propor uma correção e evitar problemas maiores.

Sistemas disponíveis na internet são oportunidades únicas para indivíduos maliciosos tentarem executar ataques e, visando mitigar este tipo de situação, que profissionais capacitados e dotados de um raciocínio lógico diferenciado, encontram-se prontos para oferecer serviços de teste de invasão e vulnerabilidade. Diante disso, podemos perceber a real importância da execução de um Pentest. Seus resultados vão muito além das descobertas e correções de falhas de segurança, eles evitam transtornos e situações constrangedoras que podem extrapolar as fronteiras da normalidade.

1.1.1 Pilares da segurança

Quando relacionamos a segurança da informação ao Pentest ou ao teste de invasão, devemos sempre mencionar os pilares fundamentais: **confidencialidade**, **integridade** e **disponibilidade**. São eles, de forma direta, que tornam o profissional de Pentest uma realidade. Cada um desses pilares, moldam de forma significativa o rumo da segurança digital e da informação.

Quando tratamos sobre **confidencialidade**, relacionamos à privacidade dos dados de uma organização. Dentro de um meio digital, a restrição ao acesso a essas informações proporciona uma medida preventiva contra o vazamento de dados pessoais, espionagem e ações criminosas. Já abordagem da **integridade** possui como foco principal a precisão e confiabilidade dos dados informacionais. Esse pilar

está diretamente relacionado ao fato de que essas informações não foram alteradas sem autorização. Assim, fechando os sustentáculos da segurança da informação, a **disponibilidade** torna a evolução digital uma realidade. É ela quem faz com que as informações ou dados estejam armazenados e disponíveis. Veja na figura: “Pilares da segurança da informação”:

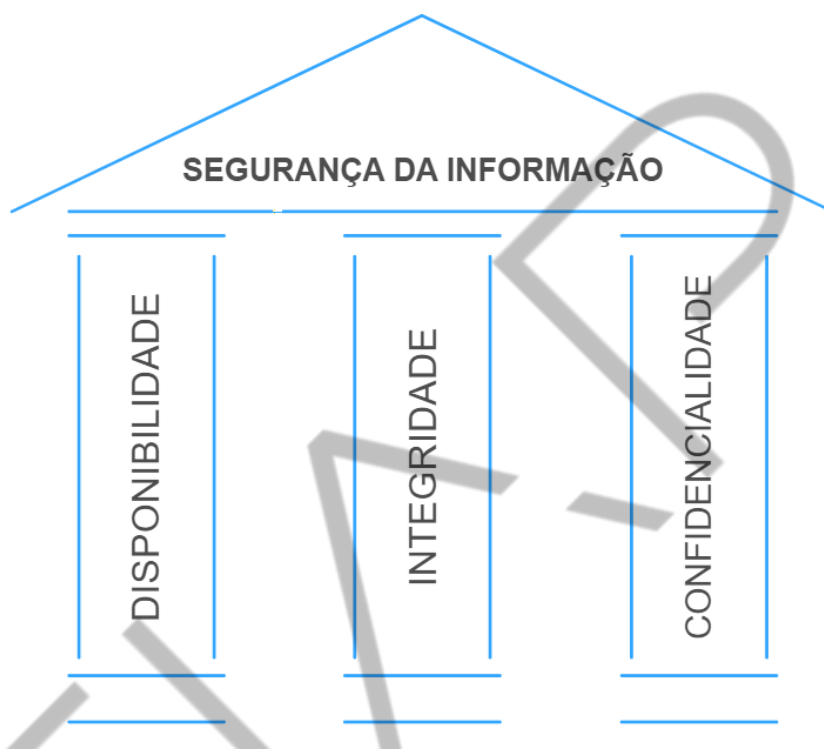


Figura 1 - Pilares da segurança da informação
Fonte: site Nsworld – pilares da segurança da informação (2018)

Todas essas definições são a base da segurança da informação e código de conduta do profissional Pentest, sem elas deixamos de ser implementadores da segurança para sermos meros idealizadores.

1.2 Tipos de teste de segurança

Diante da evolução dos meios tecnológicos, ingressamos em ambientes repletos de características diferentes. Não fugindo a esse aspecto, ressaltamos a existência de diversos tipos de testes de segurança. Neste princípio, não podemos confundir conceitos distintos. Apesar de definições e objetivos diferentes, são modalidades comumente executadas pelo mesmo profissional.

Na área da segurança, existem três tipos de testes: Pentest, análise de vulnerabilidade e RED TEAM. Cada um desses testes possui uma forma diferente ou metodologia para ser executado, mas com o mesmo objetivo: a segurança.

1.2.1 Análise de vulnerabilidades

Partindo do conceito de vulnerabilidade, é correto defini-la como uma fraqueza que pode comprometer a segurança de um sistema. Essa fraqueza age de forma a permitir que um possível atacante venha a violar qualquer um dos três pilares da segurança da informação: confiabilidade, integridade e disponibilidade. Sendo assim, a análise de vulnerabilidade é usada para identificar e fortalecer a segurança de um determinado sistema ou ambiente de trabalho, objetivando-se mitigar possíveis ataques. Nessa análise, é identificadas possíveis falhas do sistema, mapeando riscos e categorizando-os.

A análise de vulnerabilidade pode ser realizada de diversas maneiras, desde a implementação de cuidados básicos na manipulação e acesso de informações, às práticas organizacionais rotineiras. Contudo, encontra-se sempre associada à infraestrutura de TI. Listar possíveis falhas e vulnerabilidades em sistemas e *hardware* é o objetivo principal dela, mesmo que a segurança seja um dever de todos.

Basicamente, a análise de vulnerabilidade como teste de segurança costuma ser uma prática automatizada que, muitas das vezes, é executada por alguma ferramenta específica. Essas ferramentas identificam, classificam e sugerem possíveis correções às vulnerabilidades encontradas. Além disso, costumam ser ferramentas caras e que exigem um grande aparato de *hardware*.

Como exemplos de ferramentas existentes e mais utilizadas no mercado, temos o OpenVas e Nessus. O OpenVas é um scanner de vulnerabilidades de código aberto, que surgiu em 2009 e foi desenvolvido pela Greenbone Networks.

OpenVAS é um scanner de vulnerabilidade completo. Seus recursos incluem testes não autenticados, testes autenticados, vários protocolos industriais e de Internet de alto e baixo nível, ajuste de desempenho para varreduras em grande escala e uma poderosa linguagem de programação interna para implementar qualquer tipo de teste de vulnerabilidade. O scanner é acompanhado por um feed de testes de vulnerabilidade com um longo histórico e atualizações diárias. Este feed da comunidade Greenbone inclui mais de 50.000 testes de vulnerabilidade (THE GREENBONE, 2020).

Sua interface é web, intuitiva e funcional e pode ser testado por meio do acesso ao seguinte endereço:

DICA: <https://livedemo.greenbone.net/login>.

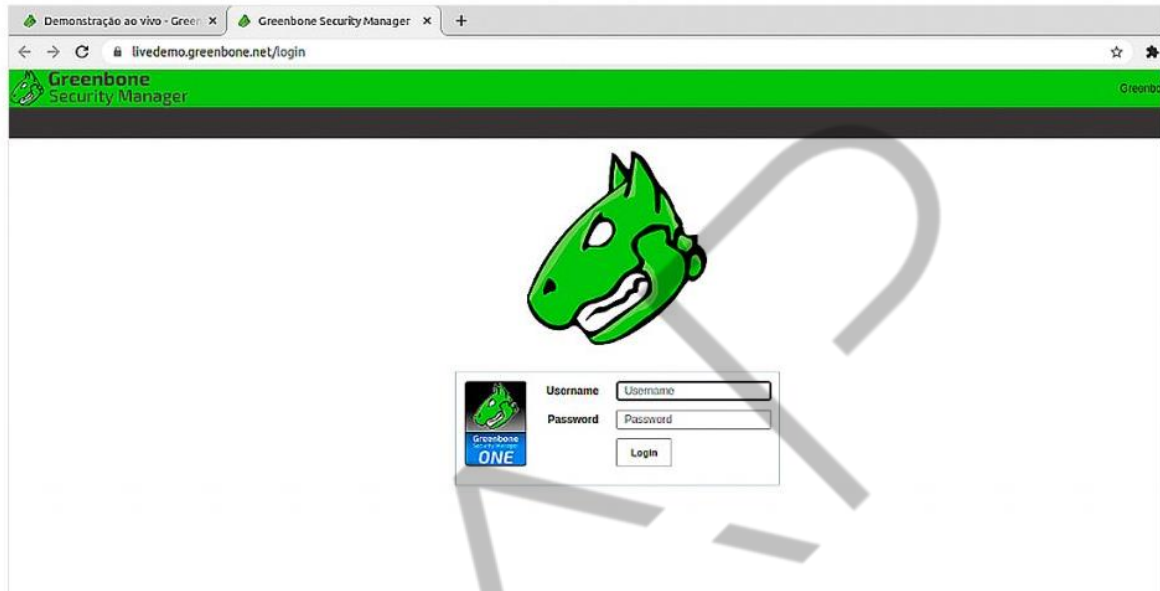


Figura 2 - Interface Web OpenVas I
Fonte: site Greebone (2020)



Figura 3 - Interface Web OpenVas II
Fonte: site Greebone (2020)

Outra ferramenta geralmente utilizada para a análise de vulnerabilidades é o Nessus profissional. O Nessus profissional também é um scanner de vulnerabilidades que suporta diversas tecnologias e possui a maior biblioteca comumente atualizada de verificações de vulnerabilidade. É um software proprietário e foi desenvolvido pela Tenable Network. Ele possui uma avaliação gratuita e que pode ser adquirida acessando o endereço abaixo e realizando um cadastro.

DICA: <https://pt-br.tenable.com/products/nessus/nessus-professional>.

Assim como o OpenVas, o Nessus também possui uma interface intuitiva e amigável, conforme a figura, “Interface Nessus profissional”:

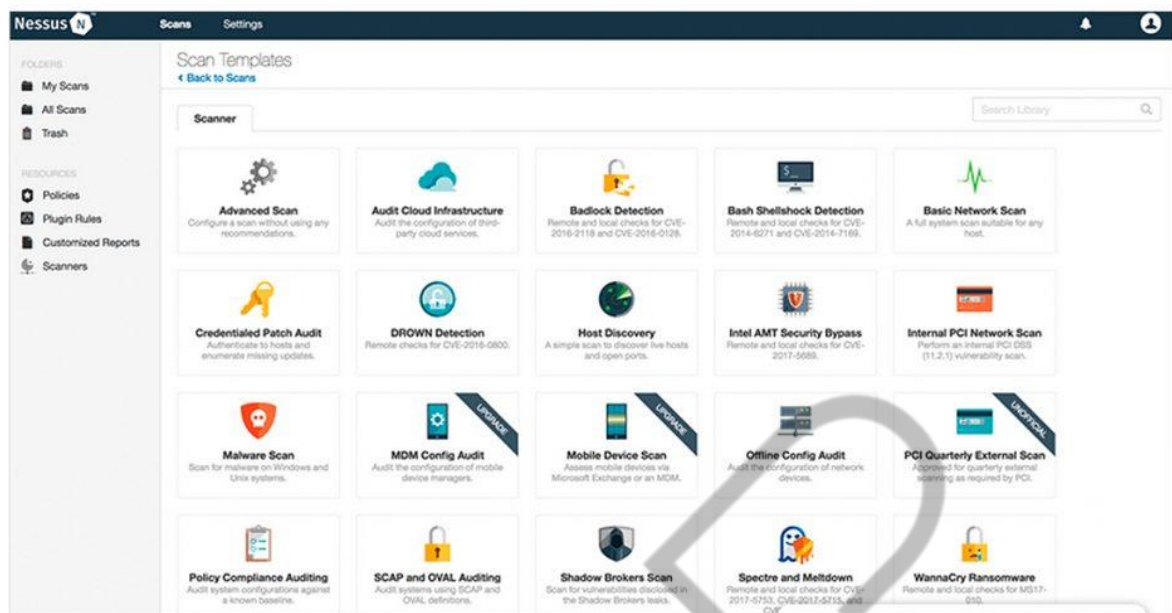


Figura 4 - Interface Nessus profissional
Fonte: site Tenable (2020)

1.2.2 Red team

O Teste de segurança Red Team consiste em uma simulação de ataque, projetada para medir o nível de eficiência dos controles de segurança física e lógica. Um teste completo de um Red Team visa expor as vulnerabilidades e os riscos relacionados às tecnologias.

A partir da aplicação de técnicas de engenharia social, campanhas de phishing e exploração de vulnerabilidades, o teste de segurança Red Team visa replicar com perfeição ataques cibernéticos externos, buscando comprometer o sistema em questão. Em geral, possui como objetivo o comprometimento do sistema, não se atentando a possíveis limites ou restrições. A utilização de todos os métodos e as técnicas disponíveis são amplamente utilizadas no processo de exploração.

O foco principal das equipes Red Team é identificar possíveis falhas existentes, que possam ser utilizadas por *insiders* mal-intencionados e que venham a comprometer ou a violar os dados de uma rede ou de uma empresa.

Quando se trata de violação de dados, não são apenas informações confidenciais que são objeto da ação maliciosa. Na atualidade, dados pessoais e dispositivos informáticos podem fornecer uma excelente motivação.

Baseada na estrutura do negócio, a operação de Red Team se adapta com extrema facilidade, visando focos de vulnerabilidades conhecidas ou não. Seu objetivo final sempre será o comprometimento do sistema e das bases de segurança da informação.

1.2.3 Pentest

Dentro da concepção dos testes de segurança, encontramos os Pentests. Por definição, Pentest ou teste de Intrusão é um método que avalia a segurança de um sistema ou rede por meio da aplicação de técnicas a ataques maliciosos. Comparado às outras modalidades de teste de segurança, em um Pentest o tempo para a sua realização é maior, exige-se um conhecimento profundo sobre programação, permitindo uma visão mais específica do risco em questão ou impacto para um negócio.

Uma característica importante do Pentest é que após a análise de vulnerabilidades, executa-se a exploração dessa falha de segurança, podendo encontrar falhas conhecidas e até mesmo desconhecidas. As técnicas utilizadas no processo é a mistura entre testes automatizados e técnicas manuais. O processo é lento e necessita de atenção para proporcionar um escopo de atuação amplo e, de certa forma, completo.

No Pentest, todas as análises e os limites de atuação são previamente regidos por contratos cujos termos são ajustados, conforme a necessidade da empresa, órgão ou repartição. De modo geral, um Pentest possui limite de tempo de atuação, escopo de técnicas de engenharia social, ferramentas e infraestruturas específicas.

Na maioria das vezes, ele é utilizado para realizar uma espécie de auditoria, descobrir o conjunto de vetores de possíveis ataques, falhas de alto e baixo risco, impactos operacionais e a reação do sistema às investidas. Possuem fases bem definidas que vão da coleta de informações à eliminação de vestígios, diferenciando-se dos demais tipos de testes de segurança.

2 MODALIDADES DE PENTEST

No contexto de Pentests, a quantidade de informações fornecidas é fundamental para um planejamento eficiente e resultados promissores. E apesar de

um planejamento, o profissional Pentester pode deparar-se com situações inusitadas e complexas.

São as informações fornecidas e as abordagens de acessos às redes ou aos sistemas que classificam as modalidades de um Pentest. Todos os dados disponíveis ou não são de extrema importância e direcionam a exploração e a correção de vulnerabilidades.

Ao abordarmos as modalidades de Pentests, verificamos a existência de três tipos: Black Box (Caixa Preta), White Box (Caixa Branca) e Grey Box (Caixa Cinza). Suas variações estão diretamente interligadas ao acesso a uma rede corporativa, às informações preliminares de colaboradores, às ações de engenharia social, ao acesso a sistemas informáticos, à infraestrutura interna e externa, entre outros.

Observando a figura: “Modalidades de Pentest”, podemos ter uma análise geral das modalidades que a ele pertence.

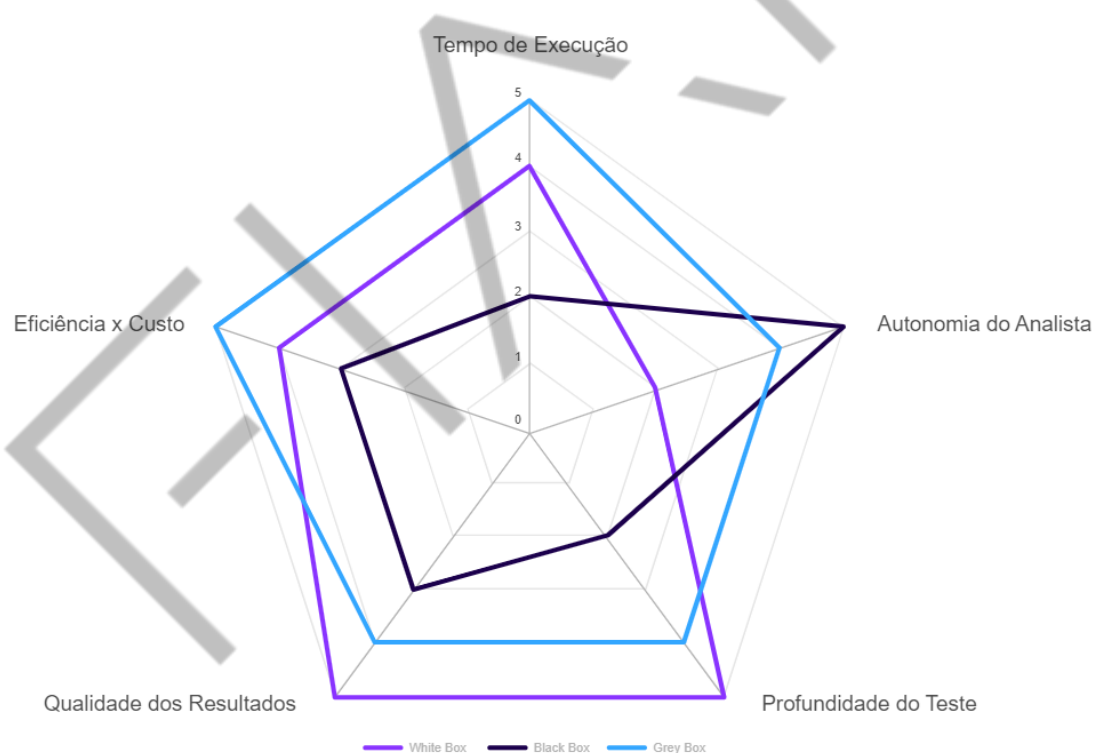


Figura 5 - Modalidades de Pentest
Fonte: site Auzac (2020)

2.1 Black box

O Pentest Black Box ou Caixa Preta constitui-se como o teste de invasão que mais se aproxima da realidade ou de um ataque externo. Nessa modalidade, é crucial que nenhuma informação por parte do contratante ou cliente, seja fornecida.

O profissional tende a realizar todas as etapas interligadas ao processo de obtenção de dados, à coleta de informações, à busca em fontes abertas, à análise de dados vazados na *Deep Web*, às redes sociais, entre outros.

O teste de invasão, concentra-se inicialmente na abordagem de colaboradores em redes sociais, páginas institucionais da empresa, campanhas de phishing, levantamento de dados da infraestrutura física, e através de contatos diretos estabelecidos. Todas essas ações deverão ser executadas com todo cuidado e anonimização, exigindo do executante muito conhecimento técnico, poder de persuasão e abordagens originais. De uma forma geral, essa modalidade requer um tempo maior de execução e paciência.

Depois da fase de coleta de dados, inicia-se o processo de levantamento de vulnerabilidades e exploração delas, finalizando o processo com um relatório das ações executadas, abordagens exitosas e das sugestões.

2.2 White box

Em contrapartida ao Pentest Black Box, a modalidade White Box ou Caixa Branca, caracteriza-se pela atividade na qual o profissional Pentester executa suas ações de análise e exploração das vulnerabilidades, a fim de obter todas as informações necessárias sobre o alvo contratante. Essas informações são dados da infraestrutura física e lógica dos colaboradores, dos sistemas informáticos, de algumas senhas de acessos, e-mails, usuários, das características de rotina, entre outros.

Nessa modalidade, realiza-se abordagens com o objetivo de identificar, monitorar e analisar vulnerabilidades diversas, como: as ações de colaboradores, as reações a ações hostis, as camadas de segurança interna implementadas, os procedimentos com dispositivos tecnológicos, a manipulação de dados de terceiros etc.

De maneira geral, o Pentest White Box é a modalidade considerada a mais ampla, com possibilidades de se identificar qualquer tipo de vulnerabilidade ou falha de segurança. Porém, não costuma ser a melhor opção, tendo em vista que o conhecimento prévio do objetivo, não seja compatível com as ações maliciosas reais.

Um ponto importante dessa modalidade de Pentest é que geralmente é utilizada para a análise de vulnerabilidades, em aplicações web, cuja observação

atinge pontos como código-fonte e rede interna. Apesar do conhecimento dos dados e procedimentos, também pode-se aproveitar esse tipo de Pentest para a realização de técnicas intensivas, na observação do projeto.

2.3 Grey box

Nessa última modalidade de Pentest, observamos que a Grey Box ou Caixa Cinza possui uma mistura das modalidades anteriores, nela o executante possui acesso a algumas informações sobre seu cliente ou objetivo. Essas informações podem ser os dados da rede interna, acesso a determinado serviço web, entre outros. Contudo, as técnicas e os procedimentos adicionais a serem empregados têm por objetivo a descoberta, a análise e a exploração de vulnerabilidades como fundamentais para o sucesso do trabalho.

Como um exemplo de uma modalidade Grey Box, encontramos a realização das análises de possíveis vulnerabilidades de segurança advindos de um usuário cadastrado, em uma aplicação. Nessa análise, verifica-se os níveis de acesso e a realização de alterações não autorizadas.

Podemos caracterizar nessa modalidade, a pequena quantidade de informações e dados fornecidos ao executante do ataque, o tempo de execução é médio e esse processo não pode ser comparado ao oferecido nas outras duas modalidades.

3 ETAPAS DO PENTEST

Para execução de um teste de invasão, a atividade deve seguir algumas etapas muito importantes. Isso requer planejamento, organização e principalmente profissionalismo. No início de uma atividade de Pentest, faz-se necessário uma comunicação efetiva entre cliente e executante a fim de que todas as atividades estejam previstas em um escopo de atuação, fornecendo segurança e confiabilidade. Além disso, faz-se necessário também ter todos os objetivos do negócio bem definidos e delimitados, ao que se refere à exploração de vulnerabilidades encontradas, para evitar situações constrangedoras, procedimentos fora do embasamento legal e prejuízos financeiros.

Diante disso, as etapas bem executadas de um Pentest, dentro dos limites estabelecidos, corroboram para a excelência do trabalho. Para um perfeito entendimento, um teste de invasão possui basicamente as seguintes etapas: Preparação, Coleta de Informações, Mapeamento de rede, Enumeração de Serviços, Análise de Vulnerabilidades, Exploração, Pós-Exploração e Relatório.

3.1 Preparação

A fase de preparação é muito importante para estabelecer o escopo de atuação, os limites da atividade, os eventuais riscos existentes, a definição do objetivo principal; quais os endereços de IP farão parte da ação no objetivo e quais não farão, quais tipos de ações o cliente permitirá que sejam executados; as permissões sobre determinado serviço; estabelecer se a exploração de vulnerabilidades farão parte das atividades permitidas ou se simplesmente será realizada uma análise de vulnerabilidades, entre outros.

É nessa fase também que o cliente define quais dias e faixas de horário os testes serão executados, visando evitar possíveis prejuízos financeiros na atividade diária, buscando não alterar rotinas de trabalho da empresa em questão.

3.2 Coleta de informações

Nessa etapa é realizada a busca e a coleta de todas as informações disponíveis sobre o alvo; emprega-se técnicas de engenharia social e processos de Open Source Intelligence (OSINT), utilizando mecanismos de busca na Internet, redes sociais e registro de domínio. Durante a busca desses dados, procura-se obter dados e informações sobre a empresa alvo, como campo de atuação, possíveis filiais, produtos fornecidos, serviços prestados, endereço, e-mails de colaboradores, clientes e fornecedores. Através das informações anteriores, objetiva-se definir os ocupantes dos altos cargos, sejam gerentes, diretores ou coordenadores.

Durante essa fase, executa-se escaneamentos de redes e coleta de informações sobre domínio, além de identificar serviços disponibilizados na internet e sistemas operacionais utilizados em sua infraestrutura. Com base nos dados e informações coletados nessa fase, podemos analisar possíveis vetores que proporcionarão o direcionamento da próxima etapa.

3.3 Mapeamento ou varredura de rede

Com as informações obtidas anteriormente, o Pentester estabelece estratégias para realizar um mapeamento de rede e serviços disponíveis, caracterizando topologia de rede, endereços IP utilizados, possíveis servidores em utilização, sistemas operacionais, quantitativo do parque computacional, possível existência de mecanismos de defesa e portas de serviços.

Junto ao DNS (*Domain Name System*), que é um sistema de gerenciamento de nomes, é possível descobrir inúmeras informações adicionais que, quando associadas aos dados existentes, proporcionam meios para o planejamento de uma exploração; a partir dessa etapa, podemos visualizar uma possível direção de ataque específica.

3.4 Enumeração de serviços

Esse processo, no transcurso de um Pentest, é uma das etapas mais importantes dessa atividade. É nesse momento que o profissional põe em prática os seus conhecimentos, técnicas de anonimização que visam, exclusivamente, a obtenção de uma informação direta sobre uma aplicação ou serviço em execução.

A enumeração de serviços extrai informações sobre a versão da aplicação em uso, a porta utilizada e a metodologia aplicada neste serviço. Vale ressaltar que, podemos confirmar se o serviço em questão, está sendo executado dentro dos padrões de segurança existentes.

Inicialmente, o Pentest coleta informações sobre serviços conhecidos, baseados nas portas abertas e *banner grabbing* das aplicações. Além desses dados, podemos, através das versões, pesquisar vulnerabilidades já conhecidas e, principalmente, traçar o perfil de padrão de segurança do ambiente utilizado. Quando um gerente de rede opta pela utilização de softwares desatualizados, inconscientemente está assumindo riscos diversos.

As verificações desse processo são realizadas, utilizando-se de ferramentas e técnicas existentes para tal operação, como: nmap, e o próprio ping.

3.5 Análise de vulnerabilidades

Com a realização do escaneamento dos serviços, passamos a deter as informações sobre as portas, softwares em execução, e serviços ativos. A partir daí, inicia-se a etapa de análise de vulnerabilidades conhecidas ou não, relacionadas às informações obtidas.

A análise de vulnerabilidades pode ser executada de forma manual ou por meio do auxílio de sistemas automatizados que, de posse de seu banco de dados de informações, torna-se possível a detecção prévia de falhas. Através de sua exploração, essas falhas podem gerar prejuízos ou danos irreparáveis, permitindo de forma inconsciente, o acesso à rede corporativa e aos seus ativos.

O profissional, no processo de análise de vulnerabilidades, utiliza-se de várias técnicas existentes, desde *brute force* à execução de códigos maliciosos sob as vulnerabilidades, exigindo um conhecimento técnico sólido.

3.6 Exploração de vulnerabilidades

Uma das etapas mais importantes do Pentest, após a execução de análise de vulnerabilidades, é a sua exploração. Nessa etapa, o profissional define o comprometimento do sistema ou não.

Na exploração de uma determinada vulnerabilidade, diversas técnicas são empregadas: SQL Injection, XSS, DDOS ou negação de serviço, buffer over flow, entre outras.

Na tentativa de conseguir o acesso não autorizado ao sistema, a persistência, paciência e a análise de uma falha (que inclui análise de código, processos, execução de solicitações e se informações inseridas no sistema são tratadas ou não), contribuem de sobremaneira para sucesso da investida. Vale ressaltar que, o acesso não autorizado ao sistema, ou inserção de dados de forma não autorizada, levam ao rompimento dos pilares básicos da segurança da informação.

Todas as etapas anteriores, quando bem executadas, conduzem ao sucesso, durante a exploração. Contudo, o processo não se encerra nesse ponto, as etapas subsequentes são pontos cruciais.

3.7 Pós-exploração

Além de conseguir o acesso, na etapa anterior, um profissional Pentester deve aplicar procedimentos para manter o acesso e levantar todos os tipos de informações disponíveis no sistema comprometido. Algumas dessas informações podem conduzir a atividade para outros ativos de rede, deixando de comprometer não só o ativo em questão, mas também a rede corporativa, obtendo acesso a dados sigilosos, sistemas internos, informações de terceiros, câmeras de vigilância, entre outros. Para que isso seja possível, o aplicador do teste de intrusão confecciona *backdoors* que garantem o acesso ao sistema mesmo com a perda da conexão, disfarça a atividade maquiando suas ações em processos verídicos do sistema, obtém senhas e acessos privilegiados.

Um detalhe importante que deve conduzir os passos do Pentest em suas ações é que nada é danificado ou inutilizado, apenas o comprometimento registra o comprometimento durante a atividade.

3.8 Relatório

Finalizando as etapas de um Pentest, tudo deve ser documentado. Todo o processo deve possuir prints de tela e explicações técnicas detalhadas do que foi feito. Nesses detalhamentos, deve-se constar dados sobre a coleta de informações, o que está exposto na Internet e o que foi vazado. Além disso, deve constar informações sobre a varredura da rede, dos escaneamentos realizados, quais serviços foram encontrados, as vulnerabilidades identificadas, como se deu o processo de análise e escolha da vulnerabilidade explorada, o seu processo de exploração, e detalhes técnicos.

Na análise de pós-exploração, deve-se embasar o comprometimento do sistema, quais informações foram obtidas, quais acessos derivados foram adquiridos, as senhas identificadas ou capturadas; como ocorreu o processo de elevação de privilégios, e ao final sugerir correções e implementações de segurança.

4 INSTALAÇÃO DO KALI LINUX

Para realizarmos os estudos práticos daqui para frente, utilizaremos o sistema operacional Kali Linux, distribuição Linux que possui todos os pré-requisitos de ferramentas para a realização da atividade de um Pentest. A imagem do sistema operacional encontra-se disponível no seguinte endereço abaixo, para o nosso laboratório utilizaremos a versão 2020.3 64 Bits.

<https://cdimage.kali.org/kali-2024.1/kali-linux-2024.1-installer-amd64.iso>.

Para instalarmos o Kali Linux do laboratório, utilizaremos o virtualizador *VirtualBox* 6.1, disponível no seguinte endereço:

<https://www.virtualbox.org/>.

A máquina virtual deverá possuir as configurações detalhadas no quadro: “Especificações do Kali Linux”.

Hypervisor	VirtualBox
Sistema Operacional	Kali Linux - 64 Bits
Memória	3 GB
Disco	80 GB
Rede	Bridge
vCPU	1

Quadro 1 - Especificações do Kali Linux

Fonte: Elaborado pelo autor (2020)

Após realizar o download dos sistemas descritos acima, partimos para a instalação do Kali Linux. Com o Virtualbox instalado no sistema, efetuamos a criação de uma máquina virtual para receber a instalação do Kali, via arquivo.iso.

Clique no botão “Novo” do Virtualbox e, conforme o quadro acima, efetue a configuração da máquina virtual, como na figura: “Configuração e Instalação Kali Linux I”, e clique em criar.

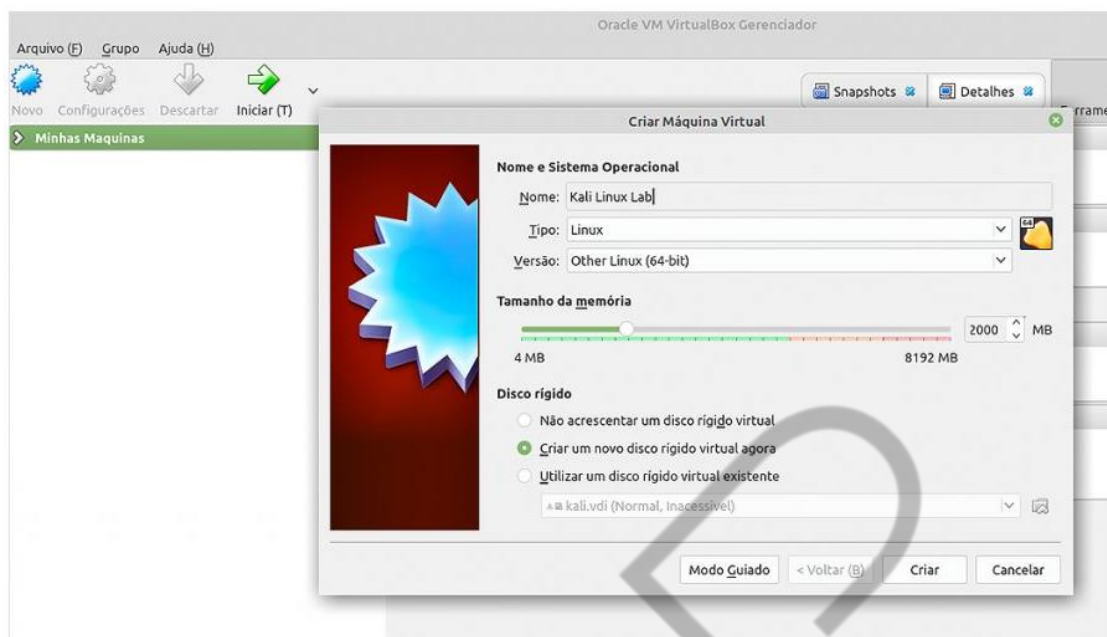


Figura 6 - Configuração e instalação Kali Linux I
Fonte: Elaborado pelo autor (2020)

Na próxima tela, selecione o tamanho do disco rígido do Kali, configurando conforme o quadro: “Especificações do Kali Linux”, e a figura: “Configuração e instalação Kali Linux II”, e clique em criar.



Figura 7 - Configuração e instalação Kali Linux II
Fonte: Elaborado pelo autor (2020)

Logo após, clicando em “configurações” e na opção “armazenamento”, selecione a controladora relacionada ao cd, e clique no símbolo de um cd com uma setinha para baixo, localizada no canto superior direito da tela, e selecione a imagem

do Kali Linux, confirme clicando no botão “ok”, conforme a figura: “Configuração e instalação Kali Linux III” e a figura: “Configuração instalação Kali Linux IV”.

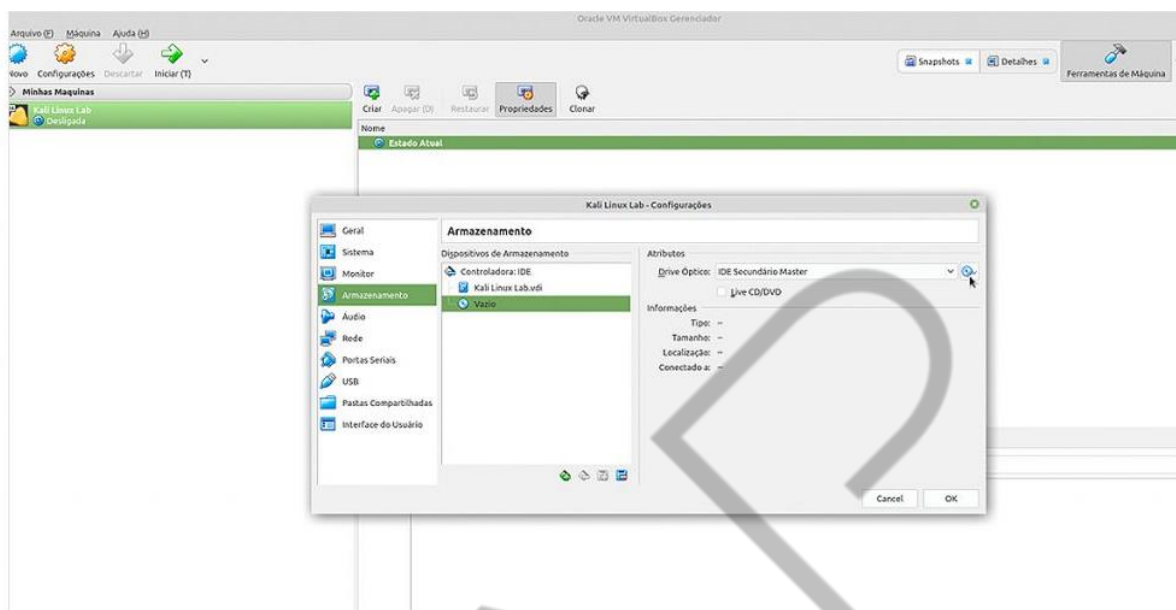


Figura 8 - Configuração e instalação Kali Linux III
Fonte: Elaborado pelo autor (2020)

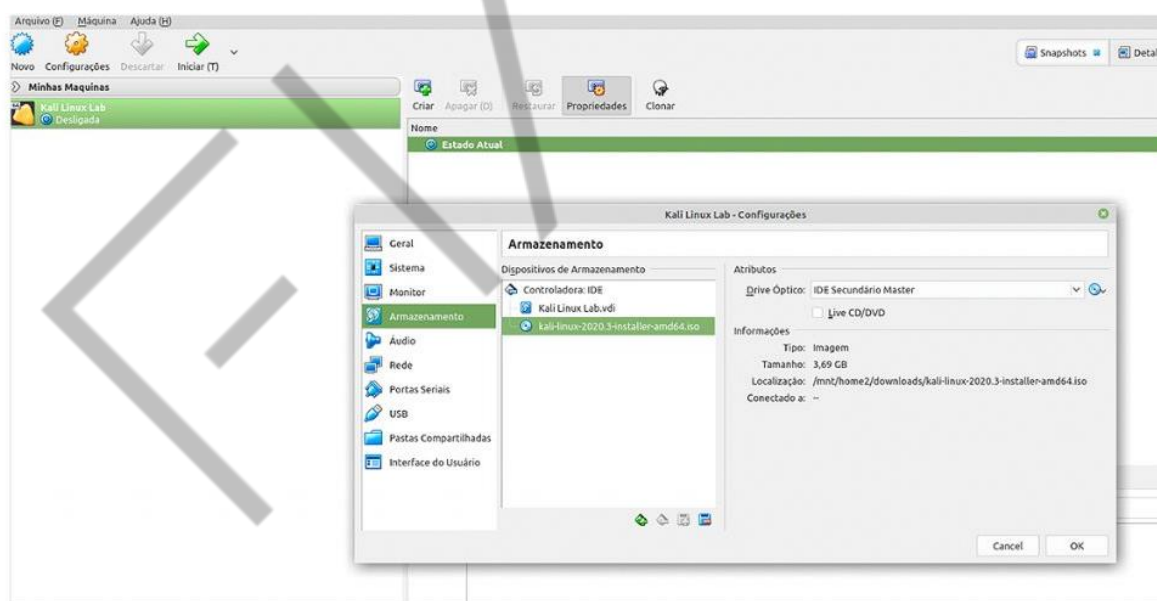


Figura 9 - Configuração instalação Kali Linux IV
Fonte: Elaborado pelo autor (2020)

Logo após a preparação, inicie a instalação da máquina virtual com o Kali, selecionando a máquina e clicando no botão “iniciar” do Virtualbox. Na tela, irá aparecer uma janela com a máquina virtual em execução, e os procedimentos para instalação do sistema operacional, como mostra a figura: “Configuração e instalação Kali Linux V”.

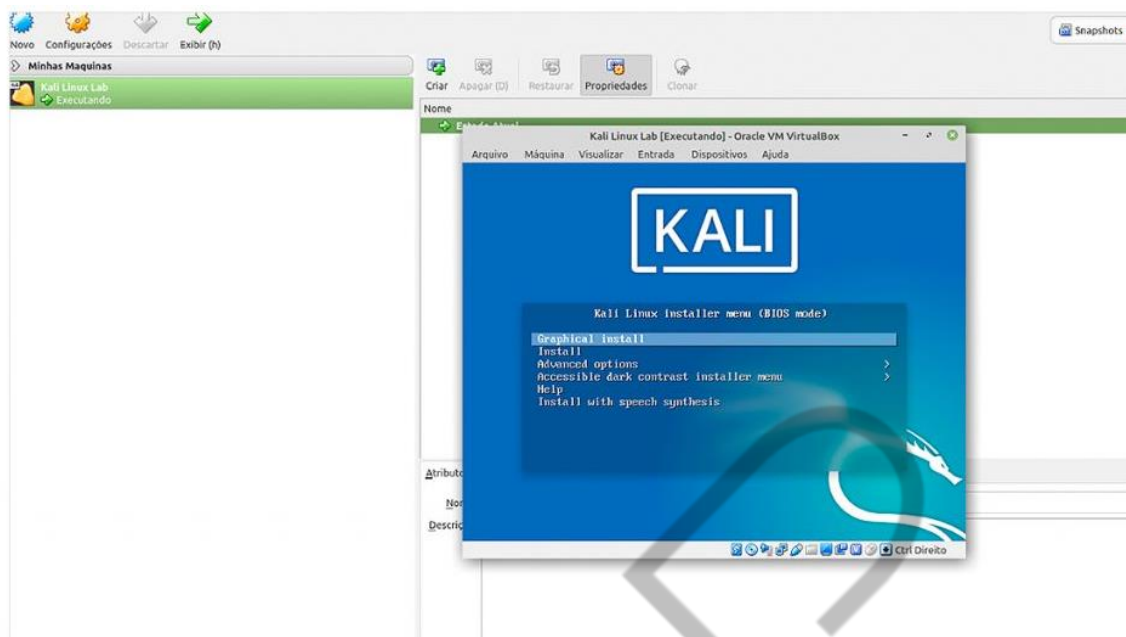


Figura 10 - Configuração e instalação Kali Linux V
Fonte: Elaborado pelo autor (2020)

Selecione a opção de “instalação gráfica”, e aperte a tecla “Enter”. O processo irá iniciar. Selecione o idioma “Português do Brasil”, clique em “continuar”; logo após selecione a localidade “Brasil” e clique em “continuar”, conforme a figura: “Configuração e instalação Kali Linux VI” e a figura: “Configuração e instalação Kali Linux VII”.

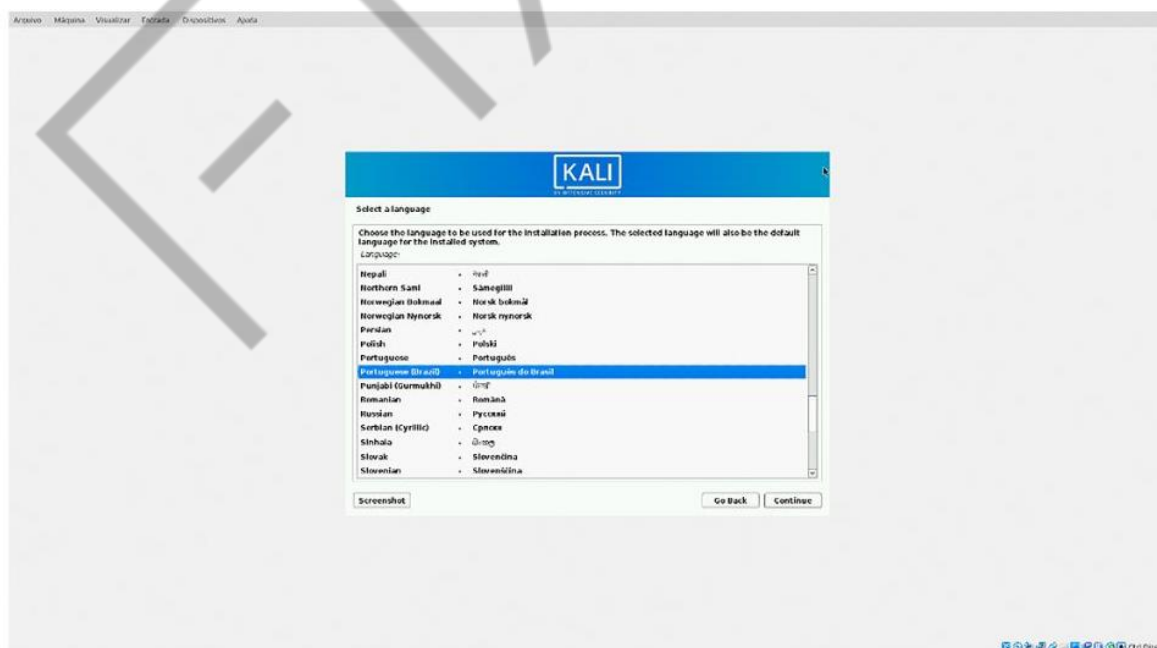


Figura 11 - Configuração e instalação Kali Linux VI
Fonte: Elaborado pelo autor (2020)



Figura 12 - Configuração e instalação Kali Linux VII
Fonte: Elaborado pelo autor (2020)

Na tela seguinte, configure o seu teclado; clique em “continuar” e aguarde a próxima tela do processo de instalação, como mostrado na figura: “Configuração e instalação Kali Linux VIII”.

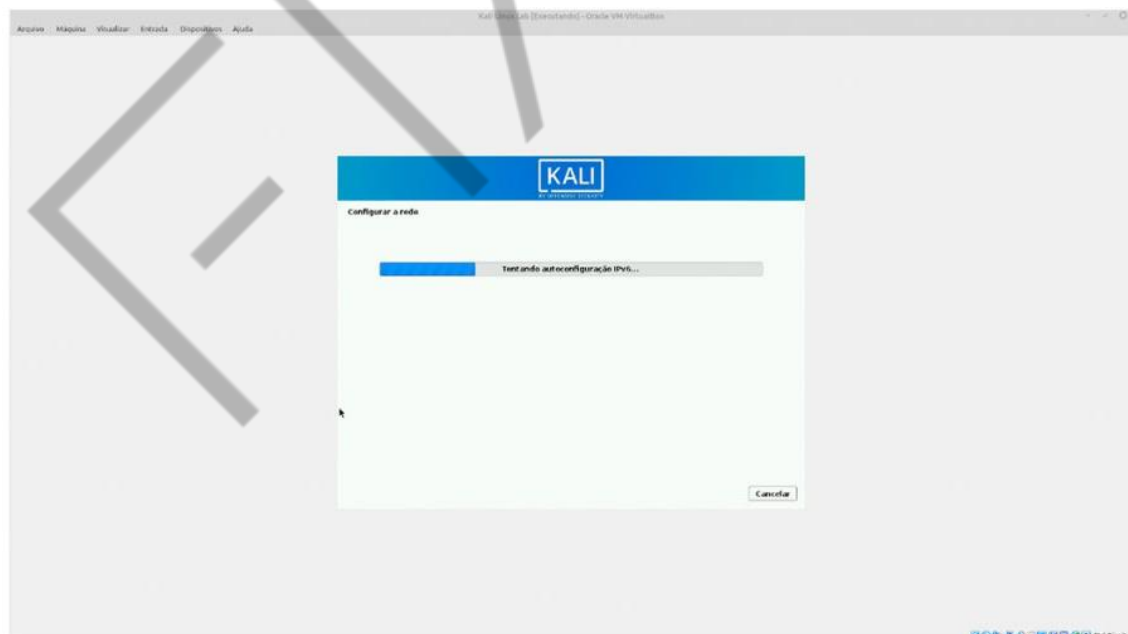


Figura 13 - Configuração e instalação Kali Linux VIII
Fonte: Elaborado pelo autor (2020)

Na tela subsequente, selecione o nome para definição do *hostname* de sua máquina, e clique em “continuar”, como na figura: “Configuração e instalação Kali

Linux IX". Na tela seguinte, deixe a informação do domínio em branco, e selecione "continuar", conforme a figura: "Configuração e instalação Kali Linux X".

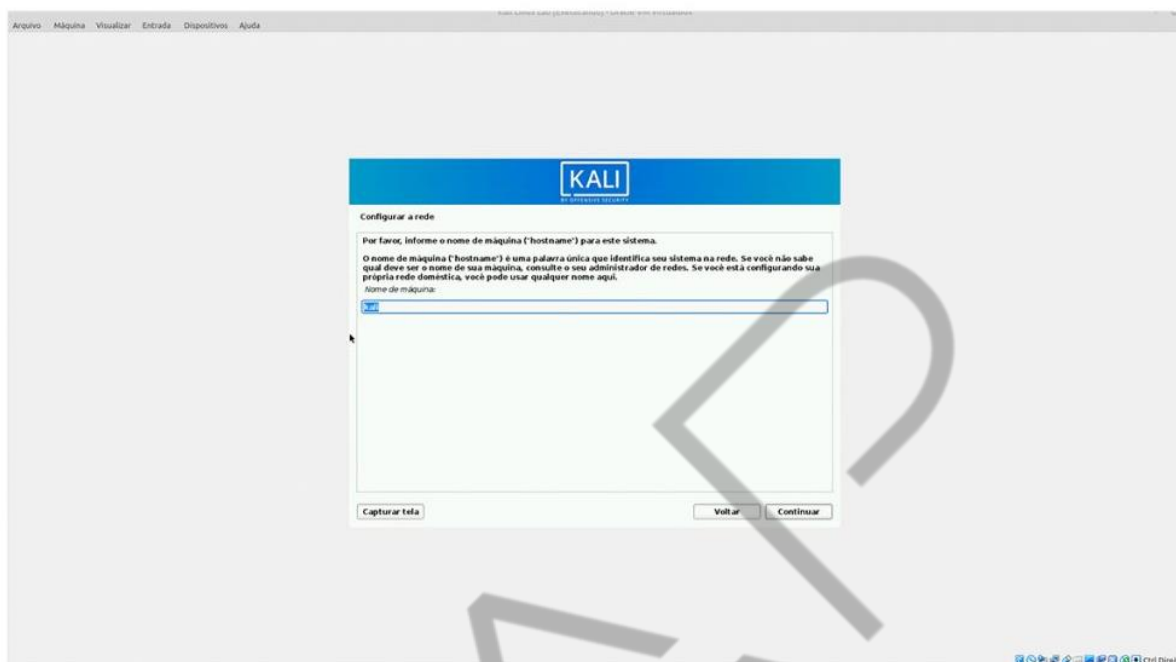


Figura 14 - Configuração e instalação Kali Linux IX
Fonte: Elaborado pelo autor (2020)

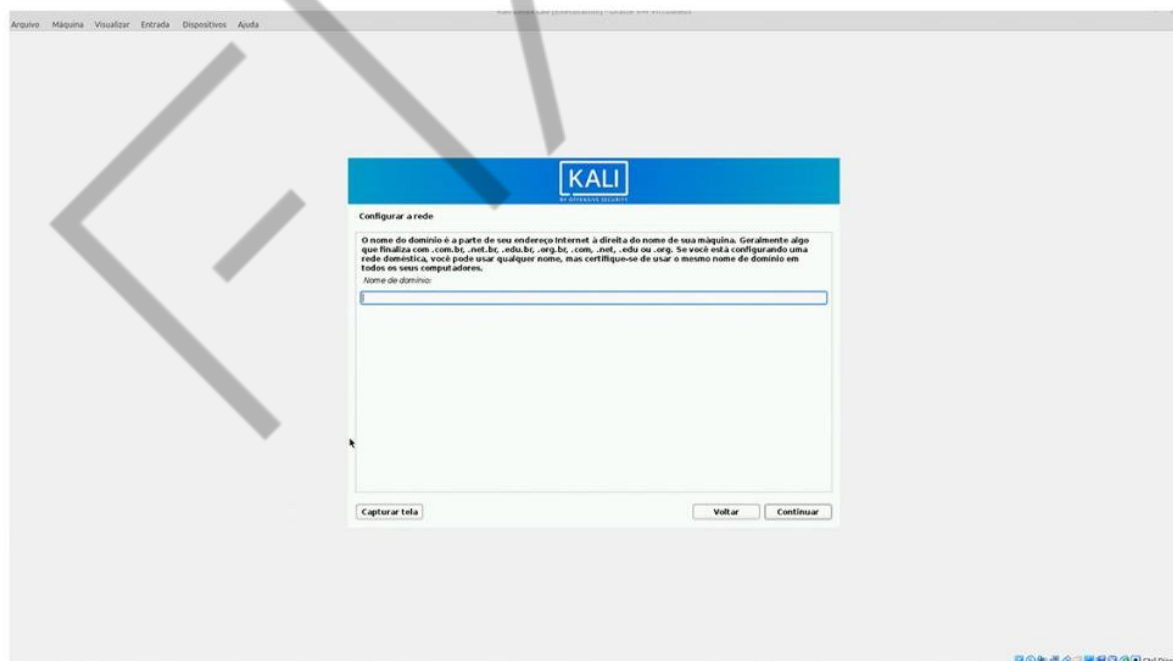


Figura 15 - Configuração e instalação Kali Linux X
Fonte: Elaborado pelo autor (2020)

Na próxima tela, digite um nome para a conta do seu usuário, que foi escolhido o nome de lab para esta conta, em seguida defina uma senha de sua preferência para esse usuário, e clique em "continuar"; aguarde a próxima tela de instalação, conforme

a figura: “Configuração e instalação Kali Linux XI” e a figura: “Configuração e instalação Kali Linux XII”.

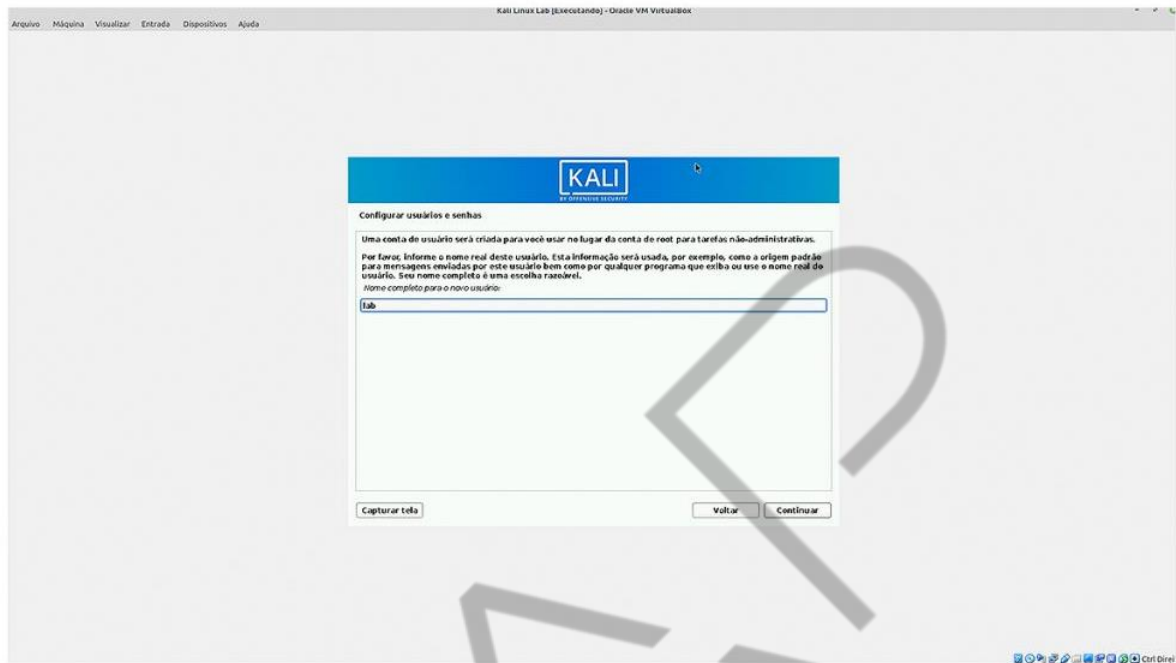


Figura 16 - Configuração e instalação Kali Linux XI
Fonte: Elaborado pelo autor (2020)

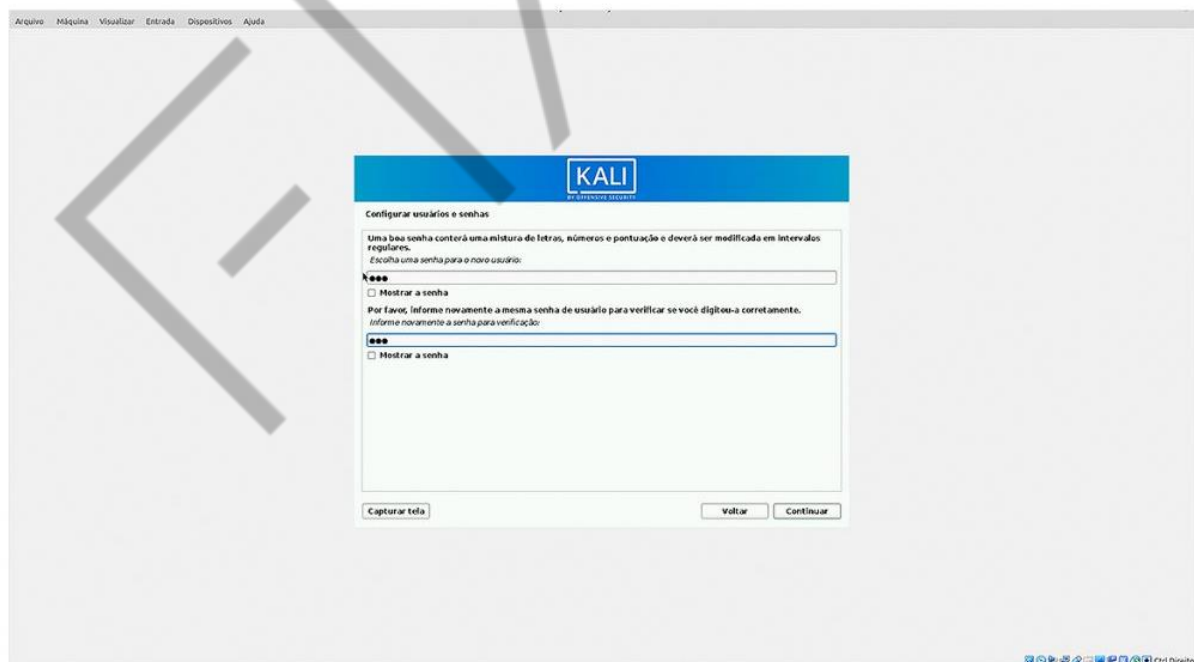


Figura 17 - Configuração e instalação Kali Linux XII
Fonte: Elaborado pelo autor (2020)

Nesse passo, selecione o fuso horário de sua região, no caso São Paulo, e clique em “continuar”. Na tela de particionamento dos discos, escolha a opção

“Assistido – usar disco inteiro”, e clique em “continuar”, como mostra a figura: “Configuração e instalação Kali Linux XIII”. Na tela seguinte, clique em “continuar” selecionando o disco rígido já criado para a máquina virtual, e selecione “continuar”, conforme a figura: “Configuração e Instalação Kali Linux XIV”.

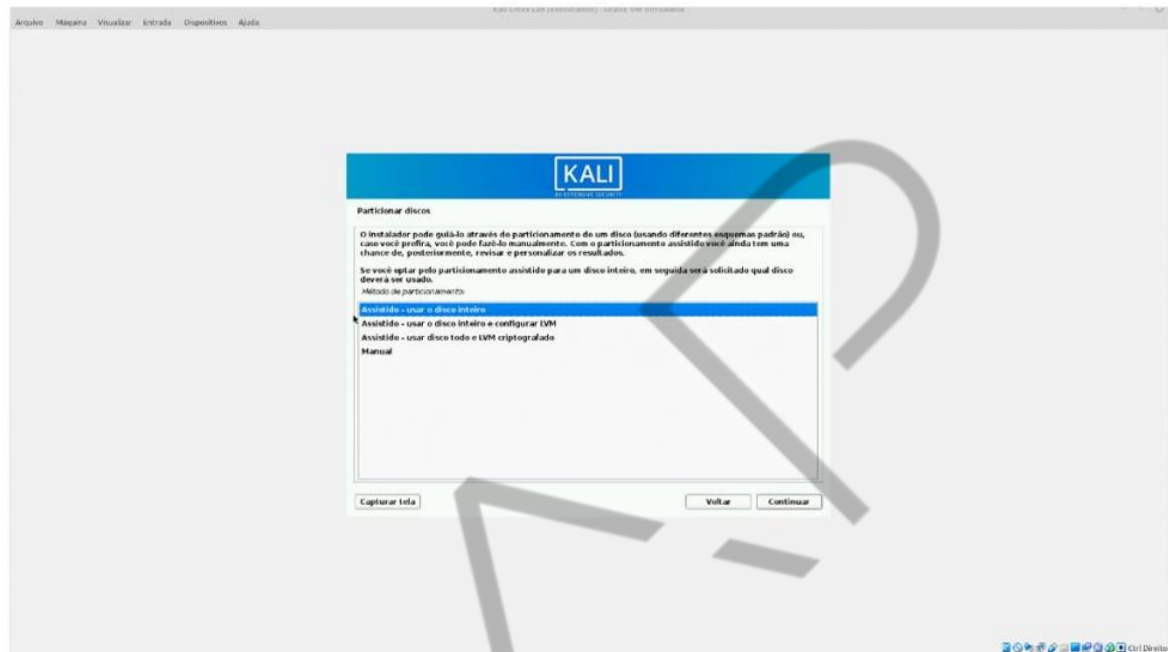


Figura 18 - Configuração e instalação Kali Linux XIII
Fonte: Elaborado pelo autor (2020)

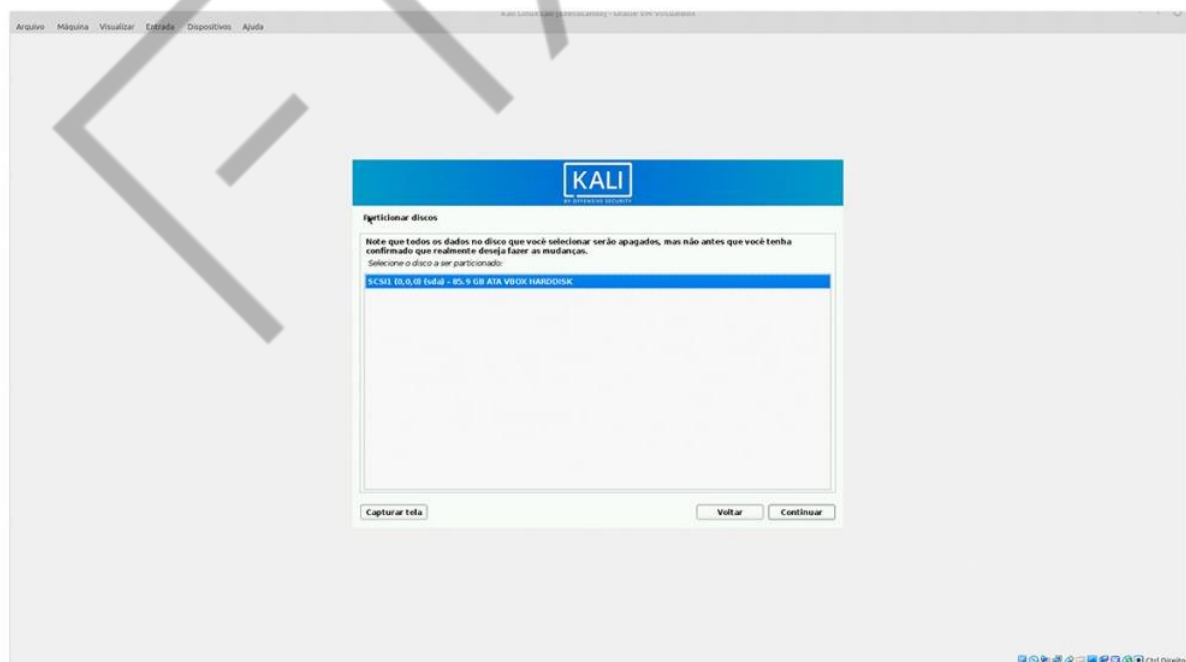


Figura 19 - Configuração e Instalação Kali Linux XIV
Fonte: Elaborado pelo autor (2020)

Opte por escolher a opção “Todos os arquivos em uma partição”, tendo em vista que o Kali estará rodando em uma máquina virtual, não exigindo configurações avançadas de particionamento de disco, conforme a figura: “Configuração e instalação Kali Linux XV”.

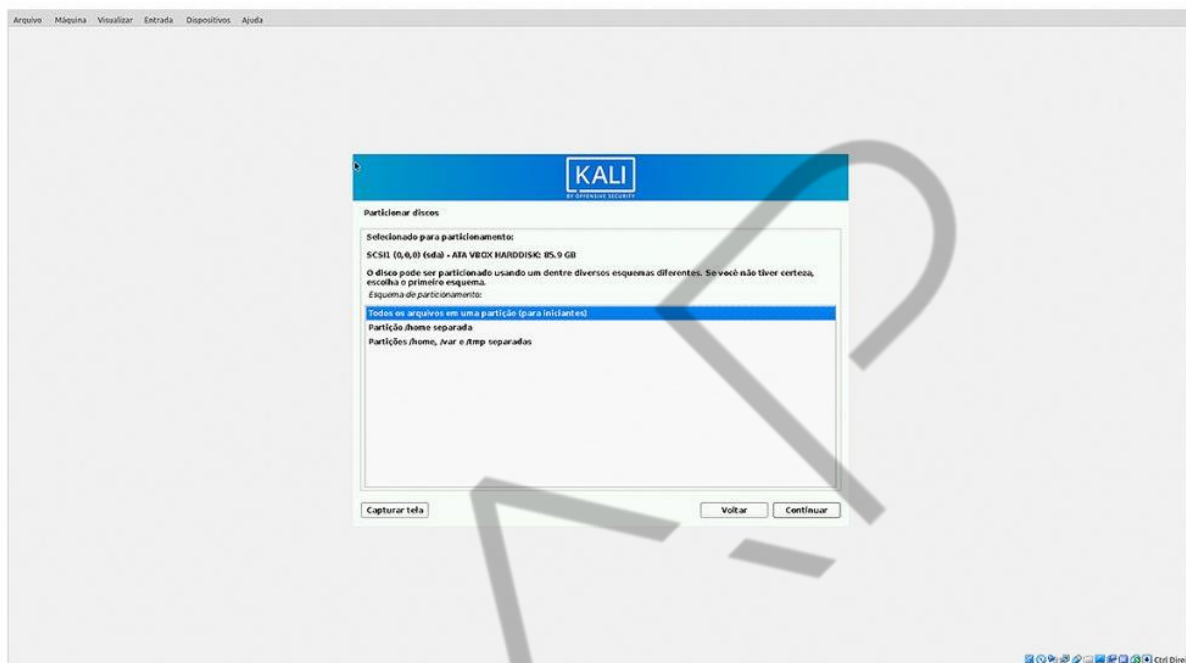


Figura 20 - Configuração e instalação Kali Linux XV
Fonte: Elaborado pelo autor (2020)

Confirme as modificações no disco, clicando em “continuar”, e escolha a opção “Finalizar o particionamento e escrever as mudanças no disco”, em seguida, “Escrever as mudanças nos discos”; clique na opção “Sim”, conforme a figura: “Configuração e instalação Kali Linux XVI” e a figura: “Configuração e instalação Kali Linux XVII”.

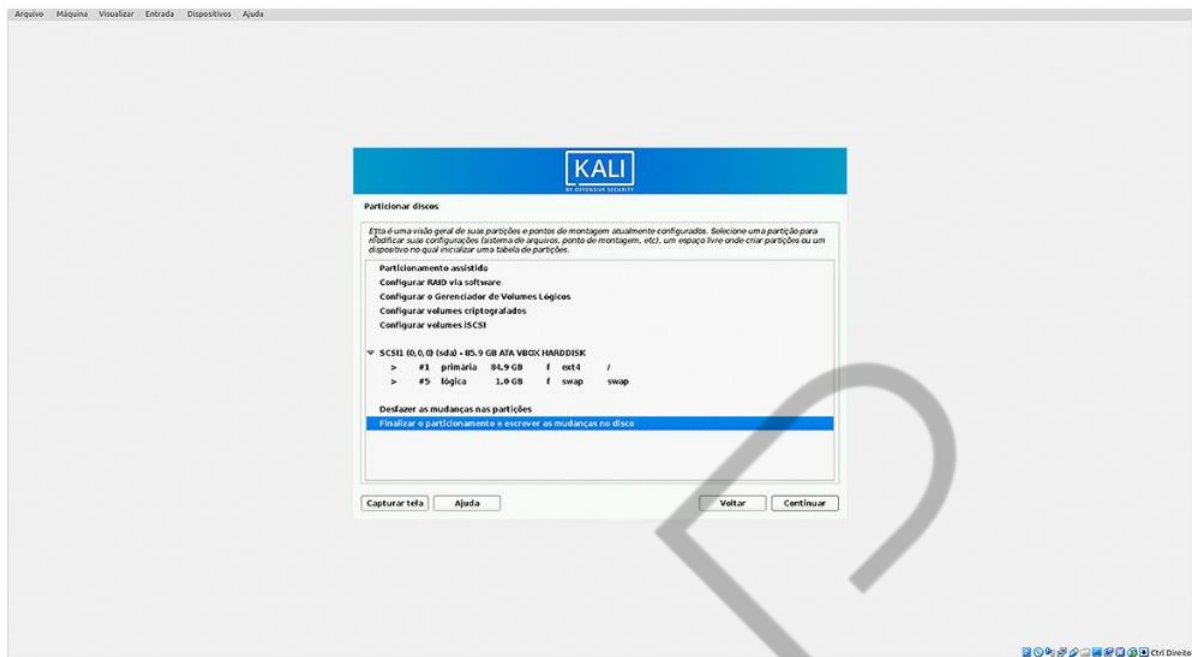


Figura 21 - Configuração e instalação Kali Linux XVI
Fonte: Elaborado pelo autor (2020)

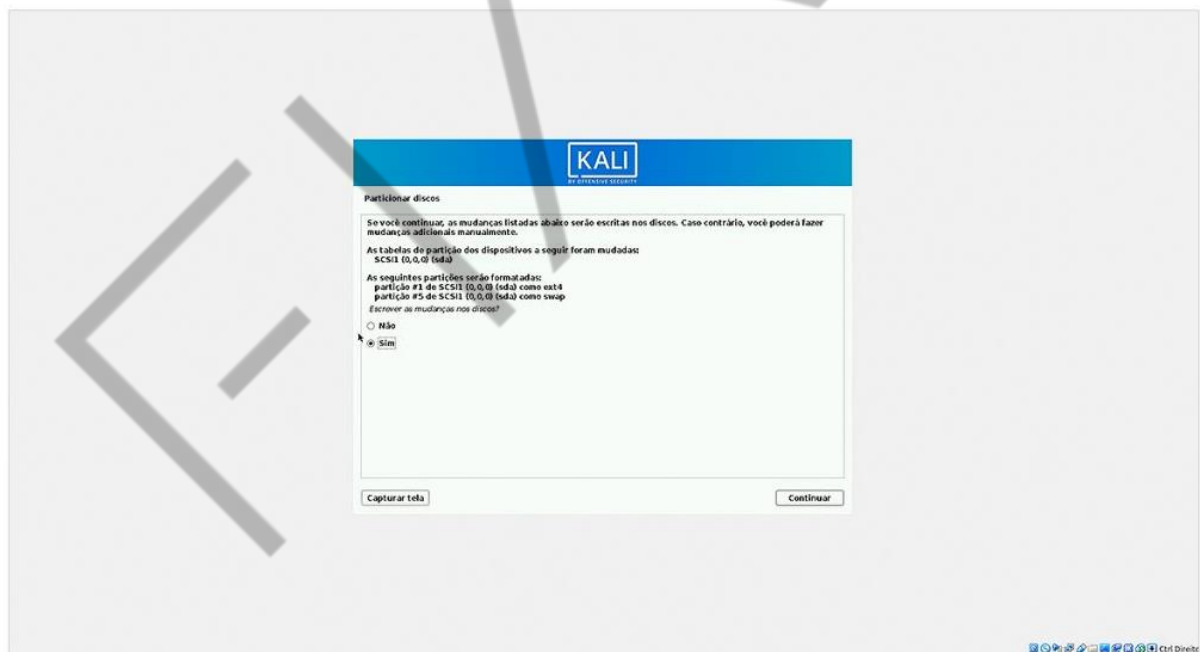


Figura 22 - Configuração e instalação Kali Linux XVII
Fonte: Elaborado pelo autor (2020)

A partir dessa etapa, o sistema operacional executará os procedimentos de instalação da distribuição em seu computador, basta apenas a conclusão da instalação, conforme a figura: “Configuração e instalação Kali Linux XVIII”.

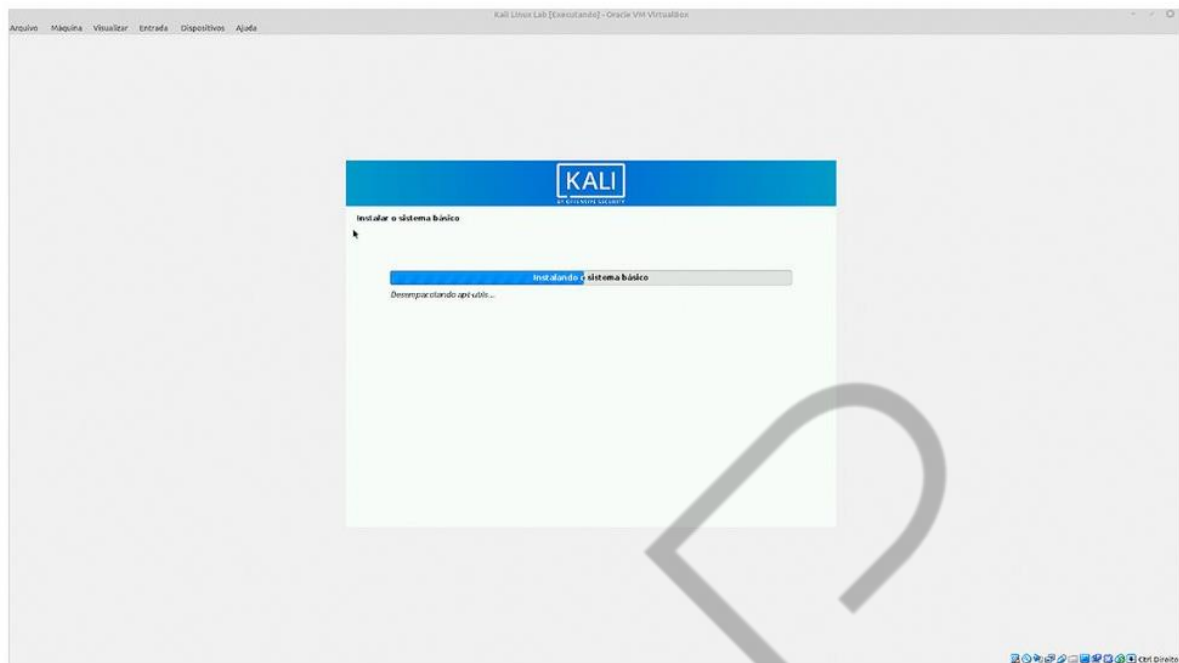


Figura 23 - Configuração e instalação Kali Linux XVIII
Fonte: Elaborado pelo autor (2020)

Na tela da seleção de software para customização do seu Kali, deixe as opções, conforme se encontra na tela, e clique em “continuar” e aguarde o processo de instalação do sistema.

Na tela de instalação do carregador de inicialização, selecione a opção “sim”, clique em “continuar”, e selecione na tela seguinte a opção correspondente ao disco rígido da máquina virtual; clique em “continuar”, conforme a figura: “Configuração e instalação Kali Linux XIX” e a figura: “Configuração e instalação Kali Linux XX”.

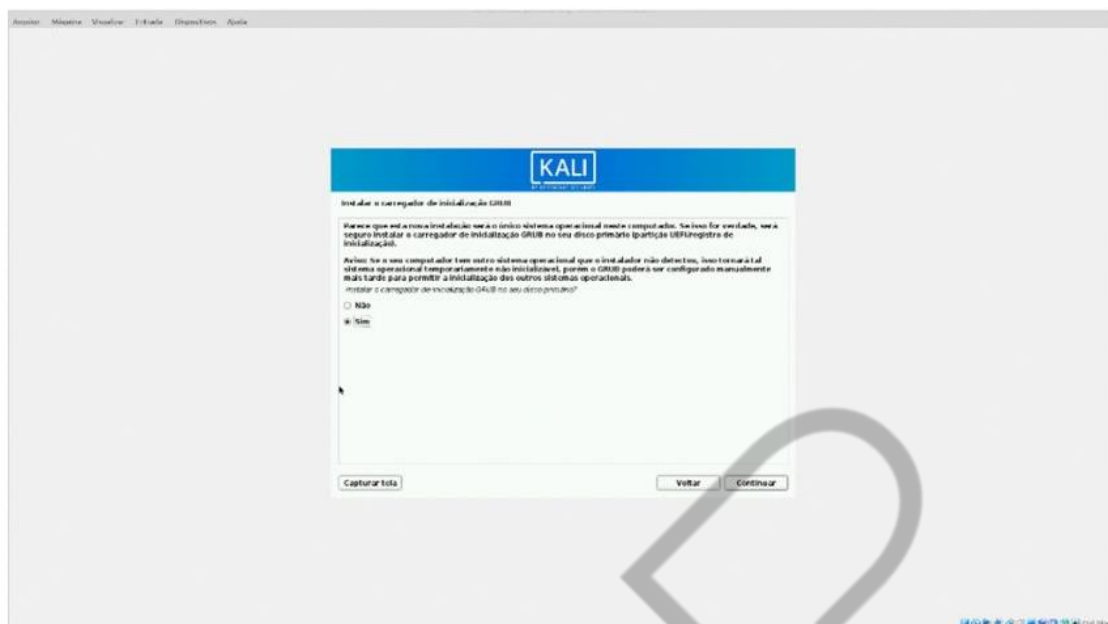


Figura 24 - Configuração e instalação Kali Linux XIX
Fonte: Elaborado pelo autor (2020)

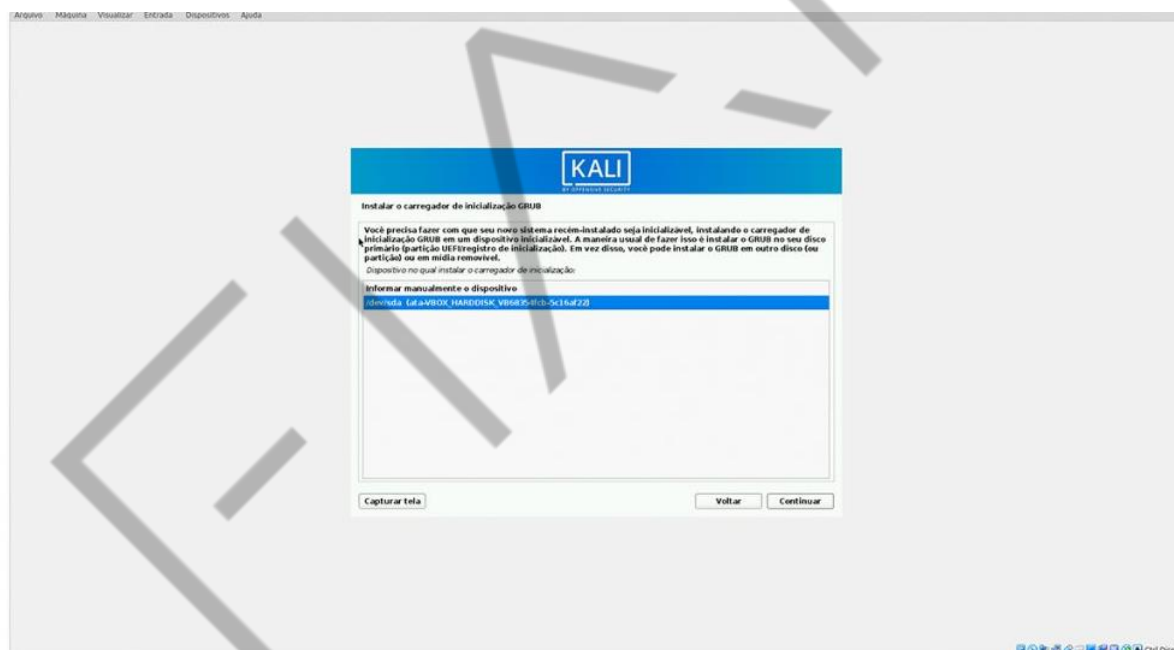


Figura 25 - Configuração e instalação Kali Linux XX
Fonte: Elaborado pelo autor (2020)

Após a finalização da instalação do sistema operacional finalizar, seu Kali estará pronto para o uso; reinicie o sistema, atentando-se para as configurações da máquina virtual, em especial, a opção de configuração do dispositivo de rede, que deve estar com a opção “Placa em modo Bridge”, conforme Figura “Configuração e instalação Kali Linux XXI”.

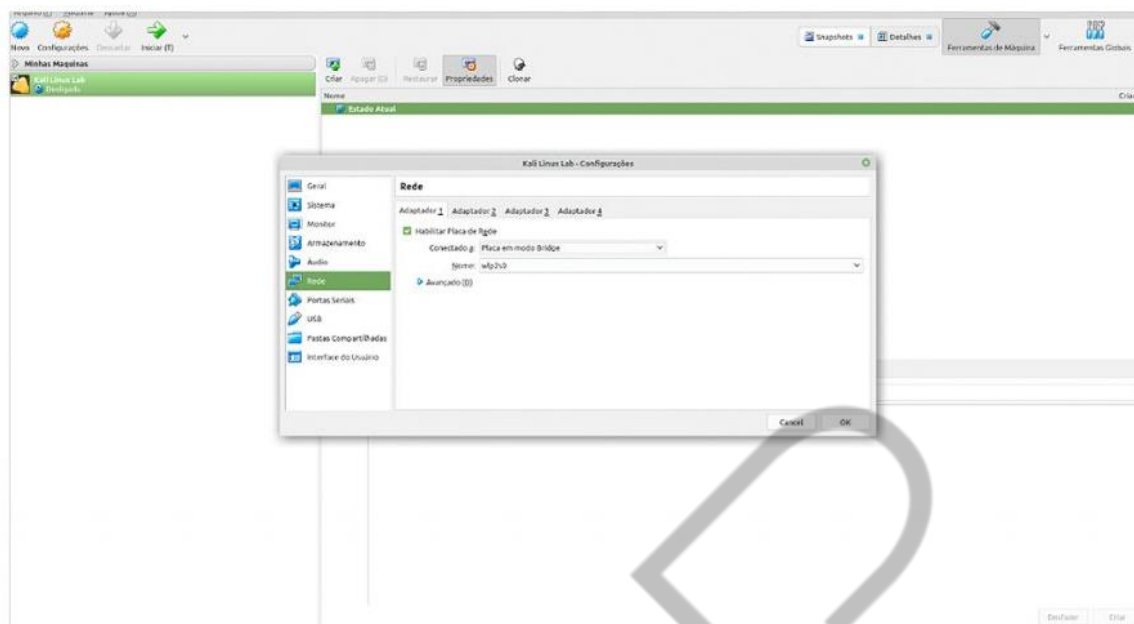


Figura 26 - Configuração e instalação Kali Linux XXI
Fonte: Elaborado pelo autor (2020)

Após inicialização da máquina, percebemos que o Kali foi instalado corretamente e se encontra em perfeito funcionamento; efetue o login com o usuário e senha criados, e finalizamos o processo de instalação. Agora, o sistema operacional está pronto para as atividades de Pentest, conforme a figura: “Configuração e instalação Kali Linux XXII”, a figura: “Configuração e instalação Kali Linux XXIII” e a figura: “Configuração e instalação Kali Linux XXIV”.

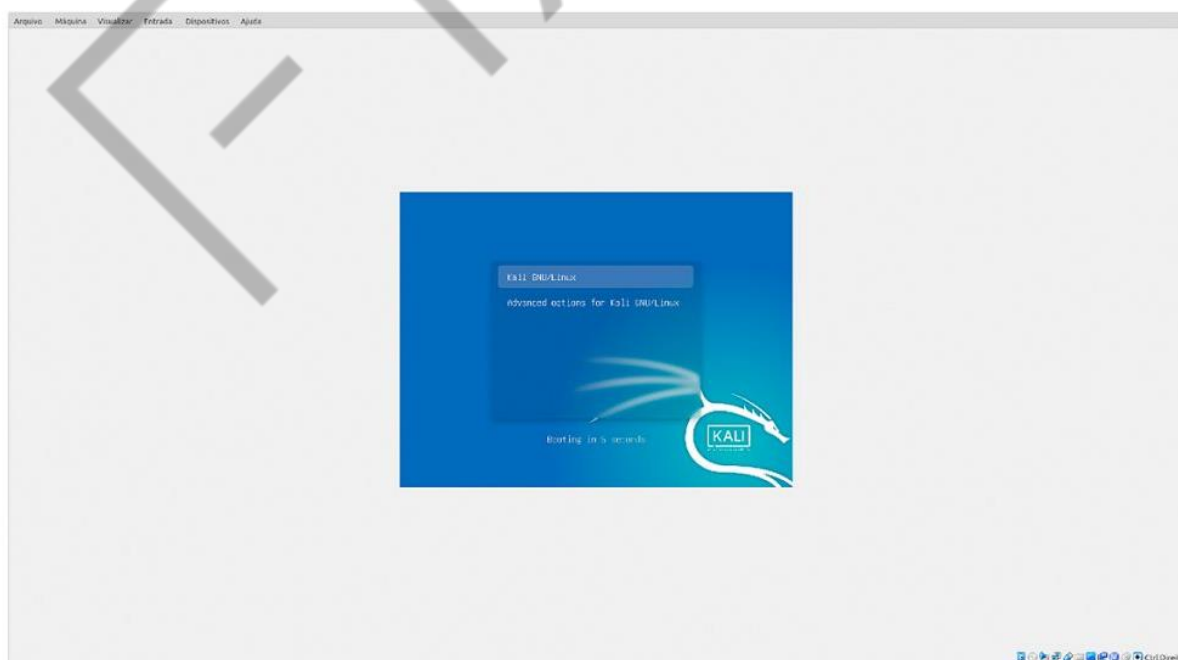


Figura 27 - Configuração e instalação Kali Linux XXII
Fonte: Elaborado pelo autor (2020)

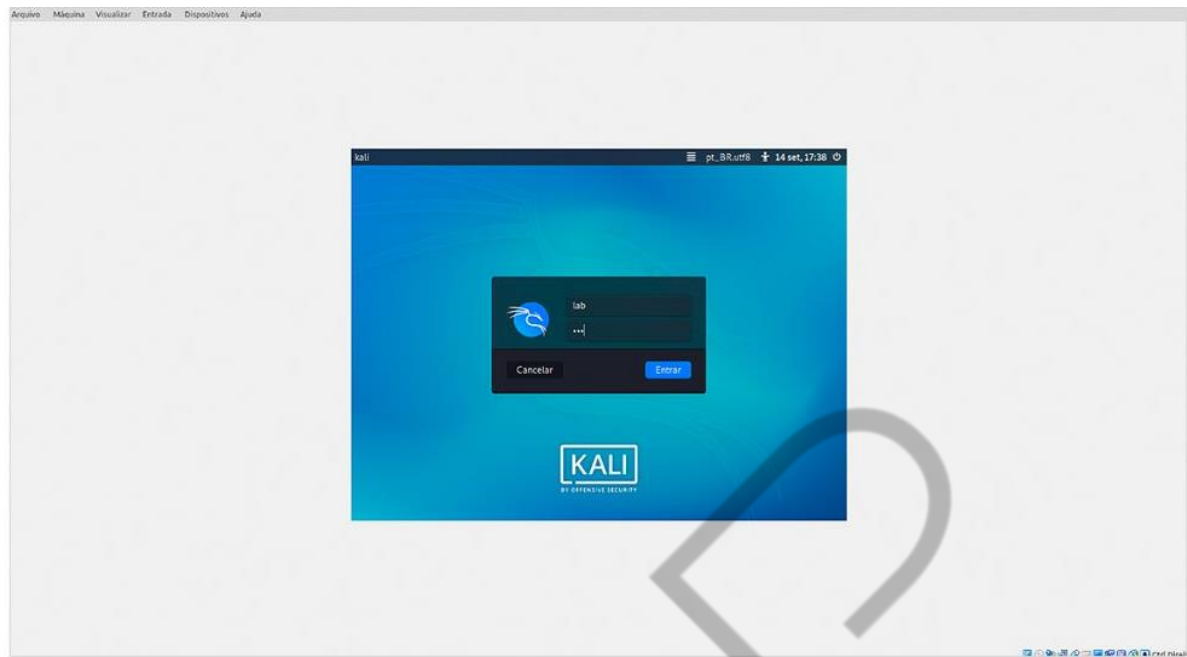


Figura 28 - Configuração e instalação Kali Linux XXIII
Fonte: Elaborado pelo autor (2020)

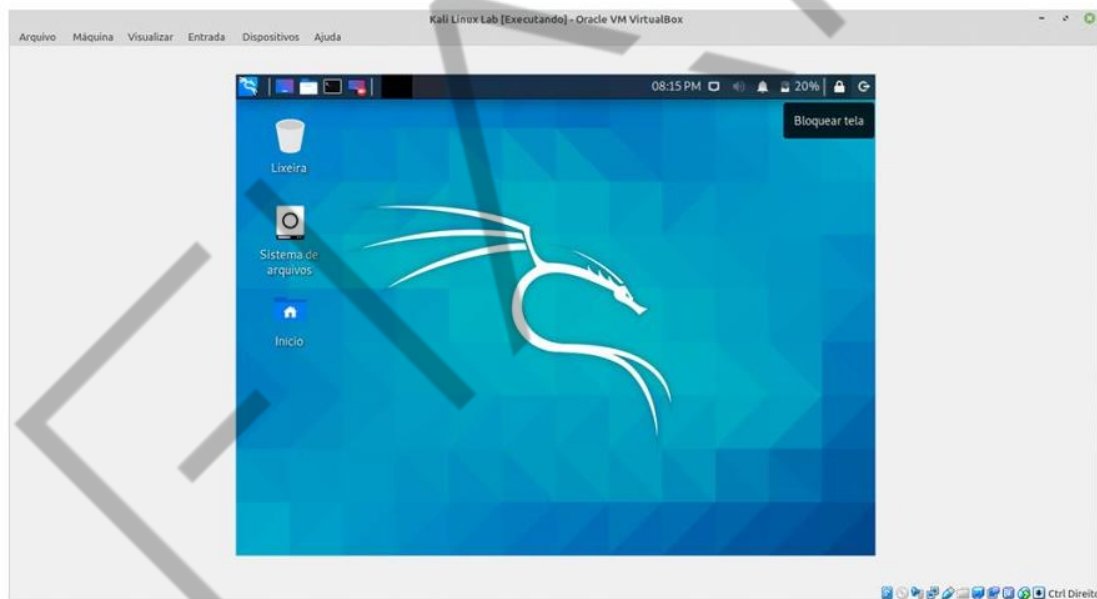


Figura 29 - Configuração e instalação Kali Linux XXIV
Fonte: Elaborado pelo autor (2020)

REFERÊNCIAS

AUZAC. **Tipos de Pentest**. 2020. Disponível em: <<http://www.auzac.com.br/testes-de-invasao/tipos-de-pentest/>>. Acesso em: 17 set. 2020.

TENABLE. **Nossa visão About-us**: capacite todas as empresas para que entendam e reduzam seu risco de segurança cibernética. 2020. Disponível em: <<https://pt-br.tenable.com/about-tenable/about-us>>. Acesso em: 17 set. 2020.

THE GREENBONE **Security Manager at Work**. Greenbone Sustainable Resilience. 2020. Disponível em: <<https://www.greenbone.net/en/live-demo/>>. Acesso em: 21 out. 2020.

WEIDMAN, G. **Testes de Invasão**: uma introdução prática ao hacking. São Paulo: Novatec, 2014. p. 576.